# Managing Security for the Analyst® Software on Stand-alone Windows 7 Workstations

Blair C. James, Stacy D. Nelson, Patrick Quinn-Paquet

# Table of Contents

**INTRODUCTION** ..... **3**

**WORKSTATION SECURITY ENVIRONMENT** ..... **3**

Configure Password Policy ..... 4
Enforce Password History ..... 4
Maximum Password Age ..... 4
Minimum Password Age ..... 4
Minimum Password Length ..... 5
Passwords Must Meet Complexity Requirements ..... 5
Store Passwords Using Reversible Encryption ..... 5
Protect the System from Password Guessing Attacks ..... 5
Account Lockout Duration ..... 6
Account Lockout Threshold ..... 6
Reset Lockout Counter ..... 6
Audit Logon Events ..... 6
Audit Logon Events ..... 7
Set and Protect the System Clock ..... 8
Configure the Windows Screen Saver ..... 8
Screen Saver ..... 9
Password Protect the Screen Saver ..... 9
Screen Saver Timeout ..... 10
Hide Screen Saver Tab ..... 10
Change the System Time ..... 10
Authentication ..... 10
Create Windows User Groups ..... 11
Add User Groups to the Analyst® Software Security Configuration ..... 12
Set File Privileges ..... 12
Set File Privileges on the Analyst Root Directory ..... 13
Manage Users ..... 13
Adding Users ..... 13
Disabling User Accounts ..... 14
Withdrawing Analyst® Software Access ..... 14

**MEMORY STICK SCANNING STATIONS** ..... **14**

**CONCLUSION** ..... **14**

**CONTACT US** ..... **14**

**REFERENCES** ..... **14**

## Introduction

Unscrupulous individuals may wish to surreptitiously alter mass spectrometry data for a variety of reasons. Among these are falsification of the data to show an untrue outcome, vandalism, and sabotage. Proper security settings are also important to prevent accidental changes or mistakes by otherwise trustworthy individuals. Additionally, regulations, such as 21 CFR Part 11, require that automated systems which generate electronic records be properly secured to prevent unauthorized access, ensure security of data, and prevent data corruption, loss, or falsification.

Recent versions of Analyst® Software are tightly integrated with the Windows 7 operating system. By properly configuring Windows 7 in tandem with the Analyst® Software, a secure and reliable environment can be maintained with minimal administrative effort.

This white paper describes the process of configuring security on a stand-alone Windows 7 workstation with Analyst® Software installed. This is guidance for experienced Windows administrators in identifying items that must be configured along with suggested optimal settings. It is important to note that if performed incorrectly, the operations described herein can severely damage the Windows operating system, rendering it unstable or unusable. Thus, it is recommended to carefully configure only those items described in this paper.

The principles and best practices described herein apply equally to stand-alone Windows workstations and Windows networks, however, these configuration settings are usually controlled by domain-level group policy in a network environment. The optimal settings in such an environment are identical to those described in this paper, but the means of configuration may differ and are beyond the scope of this paper.

Finally, there is some information about memory stick scanning stations to help prevent spreading of malware throughout the lab.

## Workstation Security Environment

Workstation security is configured using the Local Security Policy Microsoft Management Console (MMC) plug-in. To launch the Local Security Policy MMC, select Start->Control Panel->System and Security->Administrative Tools->Local Security Policy.

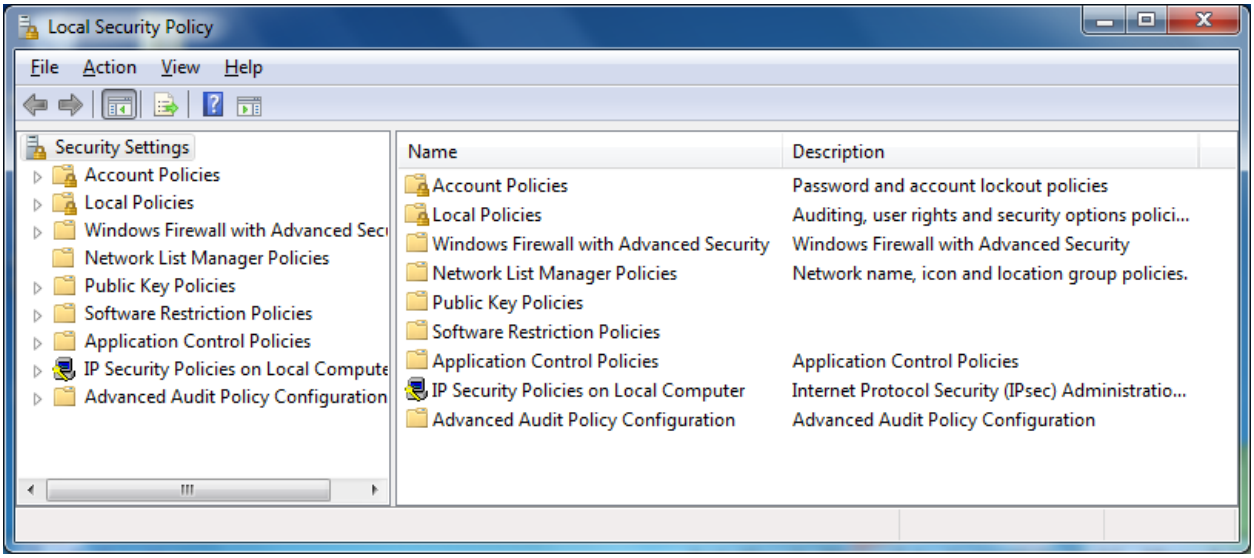



Figure 1: Local Security Policy in Microsoft Management Console (MMC)

## Configure Password Policy

To secure Analyst and to prevent unauthorized access, it is important that user accounts have strong passwords. The Windows operating system allows the establishment of password rules, which apply to all user accounts. Prior to creating user accounts, the system administrator should enable the password policy.

To set the password policy, navigate to the ***Security Settings->Account Policies->Password Policy*** folder in the Local Security Policy MMC plug-in.

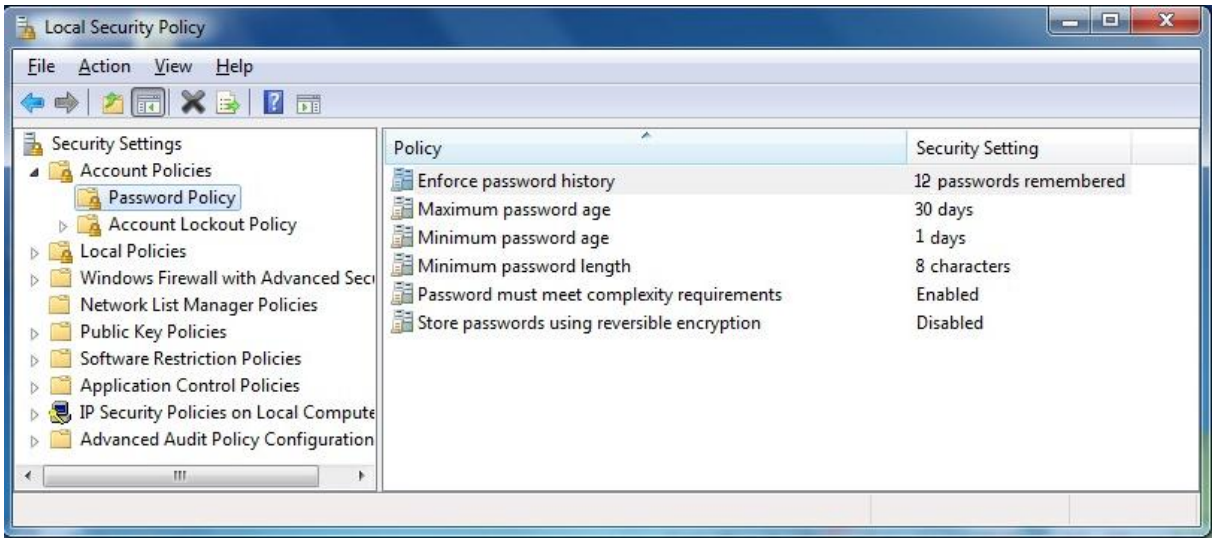



Figure 2: Password Policy

### Enforce Password History

The ***Enforce Password History*** setting prevents the re-use of previous passwords. Set this item to the number of passwords remembered. In the example in Figure 2, the last twelve passwords will be remembered.

### Maximum Password Age

The ***Maximum Password Age*** setting forces users to change passwords periodically. Set this to the number of days after which passwords expire. Typical settings are 30, 60, or 90 days. In the example in Figure 2, passwords expire at 30 days.

*Suggestion: Set "Enforce Password History" and "Maximum Password Age" so that the product of the two settings equals one year.*

### Minimum Password Age

The ***Minimum Password Age*** setting prevents users from changing a password repeatedly in rapid succession, thereby defeating the ***Enforce Password History*** setting, and allowing them to re-use a favorite password. Set the ***Minimum Password Age*** to a non-zero value. Higher values are preferable, within reason. In the example in Figure 2, 1 day is the minimum password age.

### Minimum Password Length

The ***Minimum Password Length*** determines the minimum length of account passwords. Set this item to a value of eight or more characters as shown in Figure 2. Setting to eight or more characters is important because password cracking tools are readily available that can decipher a shorter password (less than eight characters) in a matter of days or sometimes hours depending upon the complexity of the password. However, the length of time to crack a password of eight or more characters can take many years using current technology.

### Passwords Must Meet Complexity Requirements

The ***Passwords Must Meet Complexity Requirements*** setting, when enabled, requires users to construct account passwords that meet the following criteria:

- Password should not contain the user's account name or parts of the user's full name that exceed two consecutive characters
- Passwords should be at least eight characters in length
- Passwords should contain characters from three of the following four categories:
    - English uppercase characters (A through Z)
    - English lowercase characters (a through z)
    - Base 10 digits (0 through 9)
    - Non-alphabetic characters (for example, !, $, #, %)

### Store Passwords Using Reversible Encryption

Never enable the ***Store Passwords Using Reversible Encryption*** item. Doing so severely compromises the security of account passwords.

## Protect the System from Password Guessing Attacks

Account security could be compromised by an adversary repeatedly attempting to log into the system using a known username, and by guessing the password. Such an attack can be prevented using the Account Lockout Policy. To access the account lockout policy, navigate to the ***Security Settings->Account Policies->Account Lockout Policy*** folder in the Local Security Policy MMC plug-in.

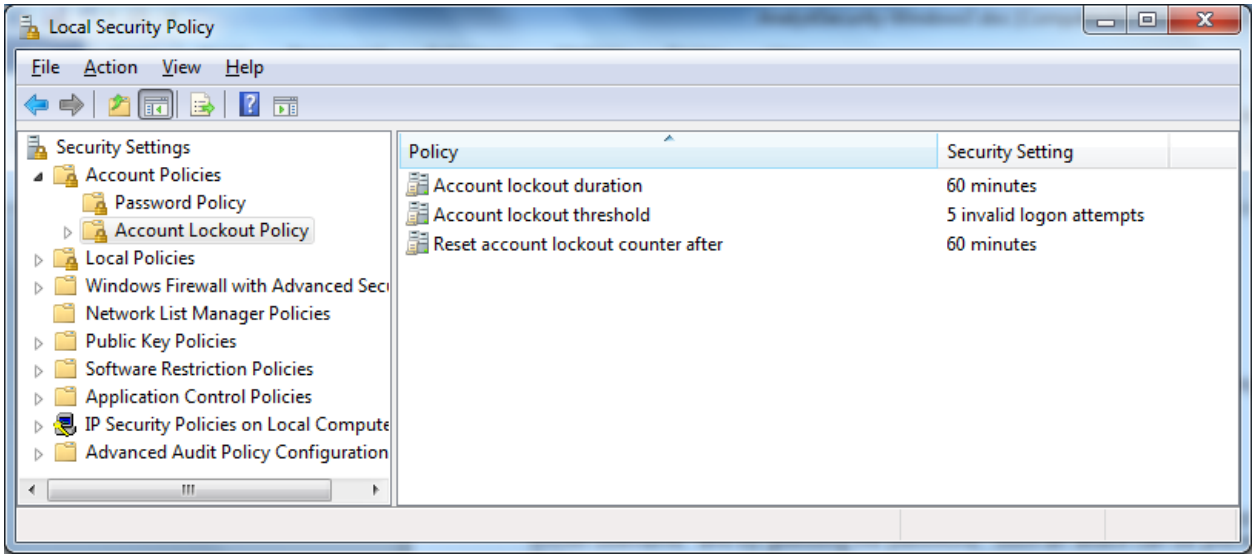



Figure 3: Account Lockout Policy

### Account Lockout Duration

The ***Account Lockout Duration*** setting determines the length of time (in minutes) that a locked-out account remains locked. A setting of zero minutes causes a locked-out account to remain locked until an Administrator explicitly unlocks the account. Set this item to either zero minutes, or to a value of 60 minutes or more. The example in Figure 3 shows an account lockout duration of 60 minutes.

### Account Lockout Threshold

The ***Account Lockout Threshold*** setting determines how many unsuccessful login attempts are permitted in a given time before the affected account is disabled temporarily. Set this to a value between three and five. The example in Figure 3 shows a value of five invalid logon attempts.

### Reset Lockout Counter

The ***Reset Lockout Counter*** setting determines the time interval (in minutes) that the lockout counter is incremented. If no unsuccessful logon attempts occur after the interval specified by the ***Reset Lockout Counter*** then the counter is reset to zero. This prevents the counter from being incremented indefinitely, which would cause the account to be permanently locked-out. Set the ***Reset Lockout Counter*** to a value between thirty and sixty minutes. Figure 3 shows the reset lockout counter set at 60 minutes.

## Audit Logon Events

To detect persistent attempts to guess account passwords, failed account logon attempts should be recorded in the Windows security event log. Administrative procedures should require that the Windows security event log be reviewed periodically and repetitive logon failures be investigated.

To access the auditing policy, navigate to the ***Security Settings->Local Policies->Audit Policy*** folder in the Local Security Policy MMC plug-in.

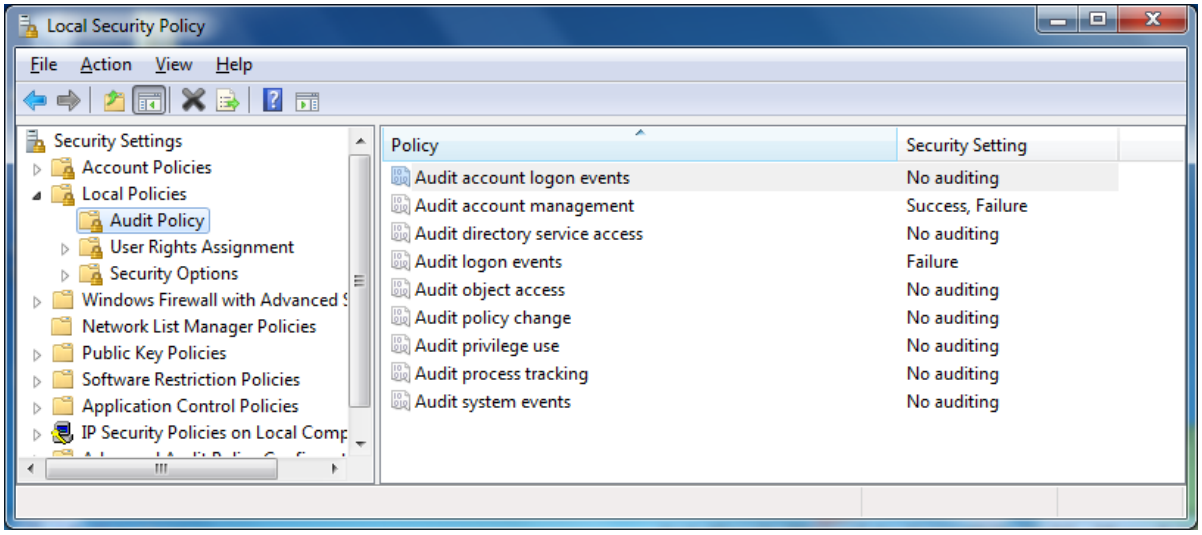



Figure 4: Audit Policy

## Audit Logon Events

The ***Audit Logon Events*** item determines whether to audit each instance of a user logging on to or logging off from a computer. Set the ***Audit Logon Events*** item to 'Failure' to cause failed logon attempts to be recorded in the Windows security event log. The log may be reviewed using the ***Control Panel->System and Security->Administrative Tools->Event Viewer*** utility.

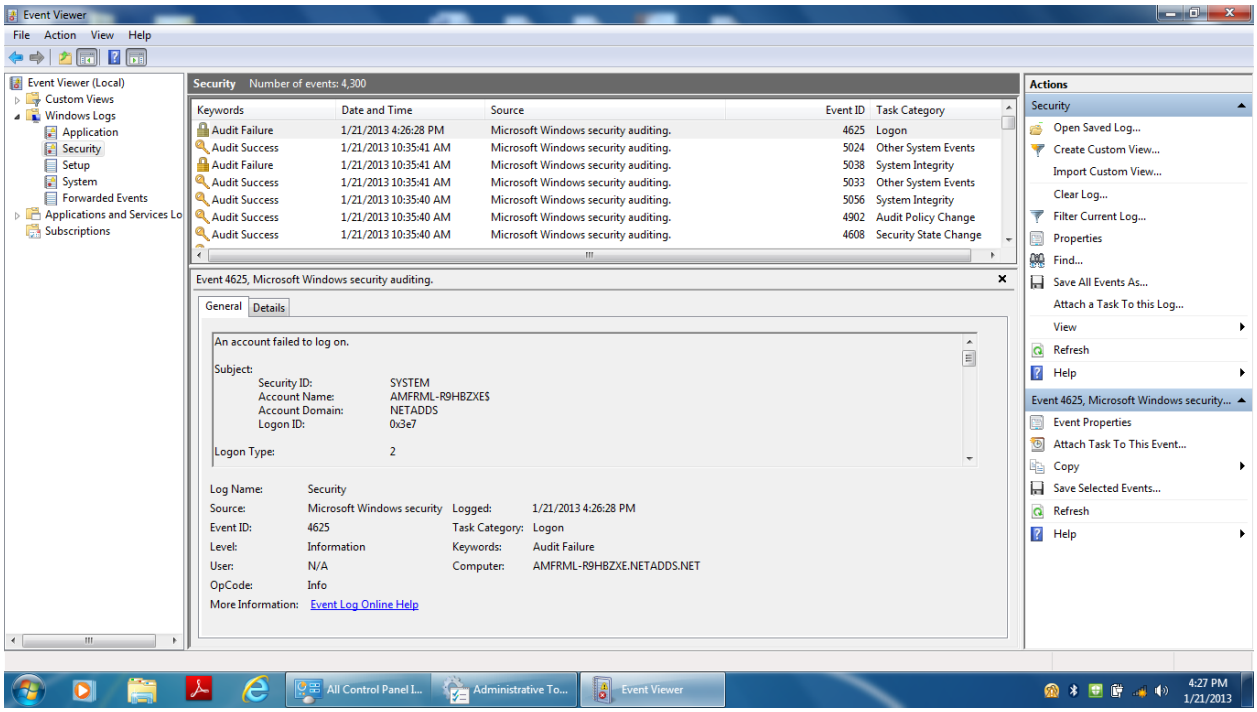



Figure 5: Sample Windows Security Event Log. The event shown is a logon failure.

## Set and Protect the System Clock

Altering the system clock can facilitate data falsification. Users should be prevented from changing the system date, time, and time zone.

Permission to change the system clock is controlled by a setting in the Local Security Policy MMC Snap-in. To launch the Local Security Policy MMC, select Start->Control Panel->System and Security->Administrative Tools->Local Security Policy. Navigate to the ***Security Settings->Local Policies->User Rights Assignment*** folder.

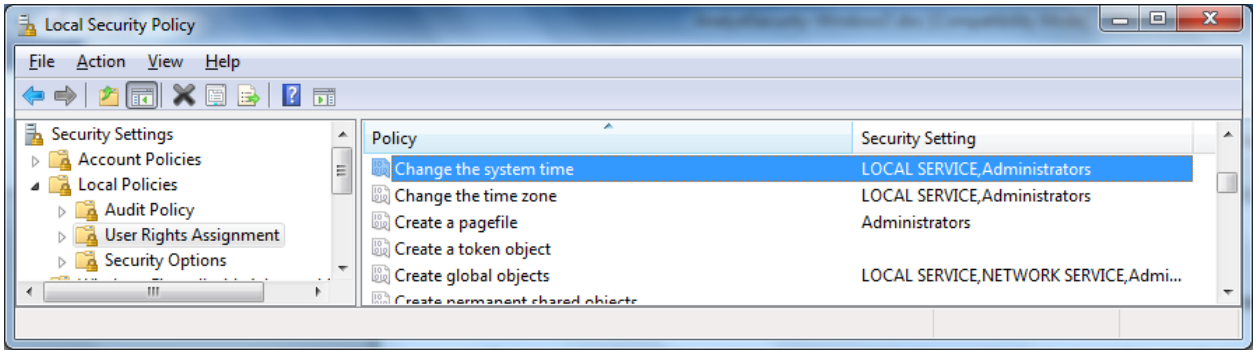



Figure 6: User Rights Assignment

## Configure the Windows Screen Saver

If users leave the workstation logged-on, but unattended, it is possible for sensitive information to be disclosed to unauthorized individuals, or for unauthorized individuals to access system resources. To prevent these security lapses, the Windows Screen Saver should be configured to obscure the screen and lock the computer after a period of inactivity.

By default, Windows screen saver settings can be modified by any workstation account. Windows 7 allows screen saver settings to be set by the administrator, and for these settings to be protected from subsequent modification. The Group Policy controls screen saver settings. Group Policy is maintained using the Group Policy Object MMC Snap-in.

To access the Group Policy Object MMC Snap-in: by following these steps:

1. Open MMC 3.0
2. On the File menu, click Add/Remove Snap-in
3. In the Available snap-ins list, click the Group Policy Object editor then click Add
4. Select “Group Policy Object” object wizard. By default all available snap-in extensions are enabled. To enable only certain extensions, highlight the snap-in in the Selected snap-ins list and click edit Extensions
5. In the Add or Remove Snap-ins dialog box, click “OK”

In the Group Policy Snap-in, navigate to the “Local Computer Policy->User Configuration->Administrative Templates->Control Panel->Personalization folder.

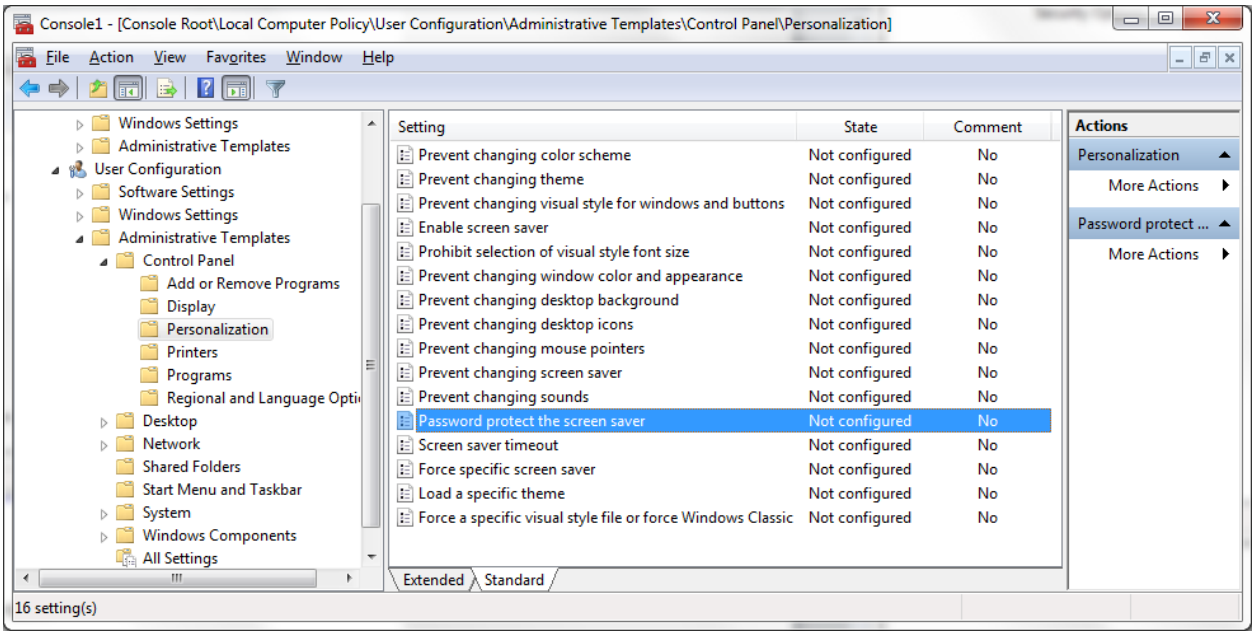



Figure 7: Group Policy – Personalization

## Screen Saver

Turn on the Windows screen saver by enabling the ***Enable Screen Saver*** setting.

## Password Protect the Screen Saver

Enable the ***Password Protect the Screen Saver*** setting to require that the current user's (or an Administrator's) password be entered to clear the screen saver.

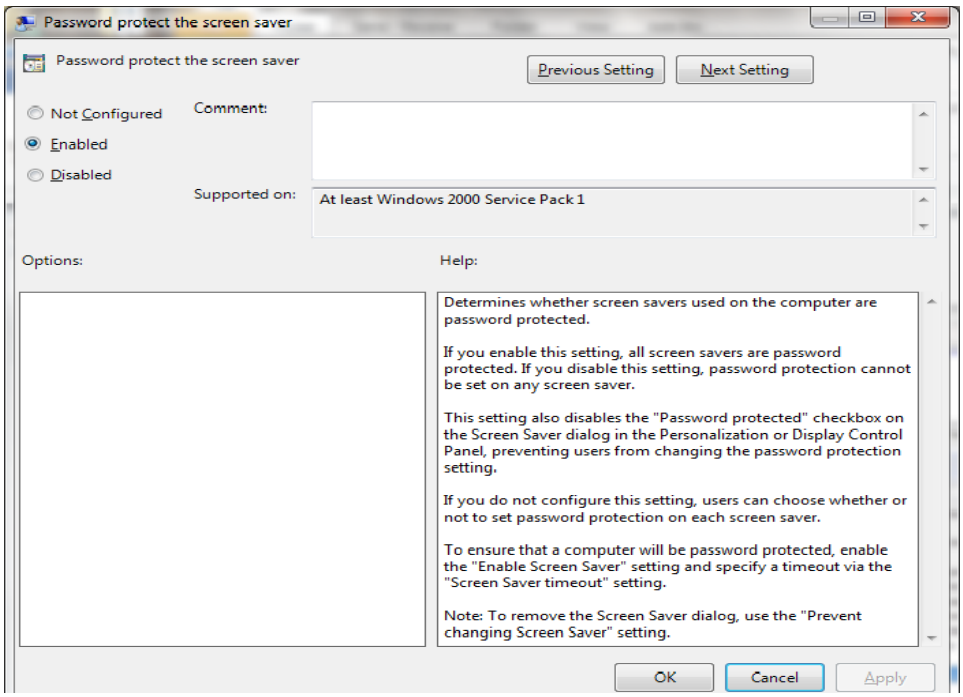



Figure 9: Enable Password Protection for the Screen Saver

### Screen Saver Timeout

Set ***Screen Saver Timeout*** to enabled and enter the desired timeout in seconds. Typical settings range from 600 (10 minutes) to 1800 (30 minutes). This value should be low enough to keep the workstation secure, but high enough that user's productivity is not hampered.

### Hide Screen Saver Tab

Optionally, enable the ***Hide Screen Saver Tab*** item to remove the "Screen Saver" tab from the display preferences dialog. This is not strictly necessary, because users will not be able to change screen saver settings even if access to the "Screen Saver" tab is permitted.

### Change the System Time

Set ***Change the System Time*** to 'Administrators' to prevent any user not in the Administrators group from modifying system clock settings.

## Authentication

The Analyst® Software can be configured to use Windows Groups rather than individual user account names to control authentication and role assignments. Using Windows Groups for authentication allows all user provisioning to be performed at the Windows level, freeing the administrator from the burden of updating both Windows account settings and the Analyst® Software security configuration when users are added or removed.

For purposes of discussion, the following simple hierarchy of roles will be used:

| Role | Description |
|---|---|
| Administrator | Analyst® Software Administrator |
| Analyst | Analyst user who creates methods, acquires, processes, and reports data |
| Operator | Analyst user who operates the instrument and acquires data. Does not create or modify methods, process or analyze data |
| QA Reviewer | Quality Assurance representative who reviews data. Does not operate the instrument, or perform any operations that alter data |

Table 1: Analyst Roles

## Create Windows User Groups

For each role to be established in the Analyst® Software, one Windows user group should be established.

| Analyst Role | Windows User Group |
|---|---|
| Administrator | analyst_administrators |
| Analyst | analyst_analysts |
| Operator | analyst_operators |
| QA Reviewer | analyst_qa_reviewers |

Table 2: Analyst Roles and User Groups

Windows User Groups are created using the Computer Management snap-in of the Microsoft Management Console (MMC). Log into the Windows operating system as a user with local computer administrator privileges. Launch the Computer Management MMC snap-in from the Control Panel by opening System and Security->Administrative Tools, and selecting 'Computer Management'. Navigate to the ***Local Users and Groups->Groups*** folder.

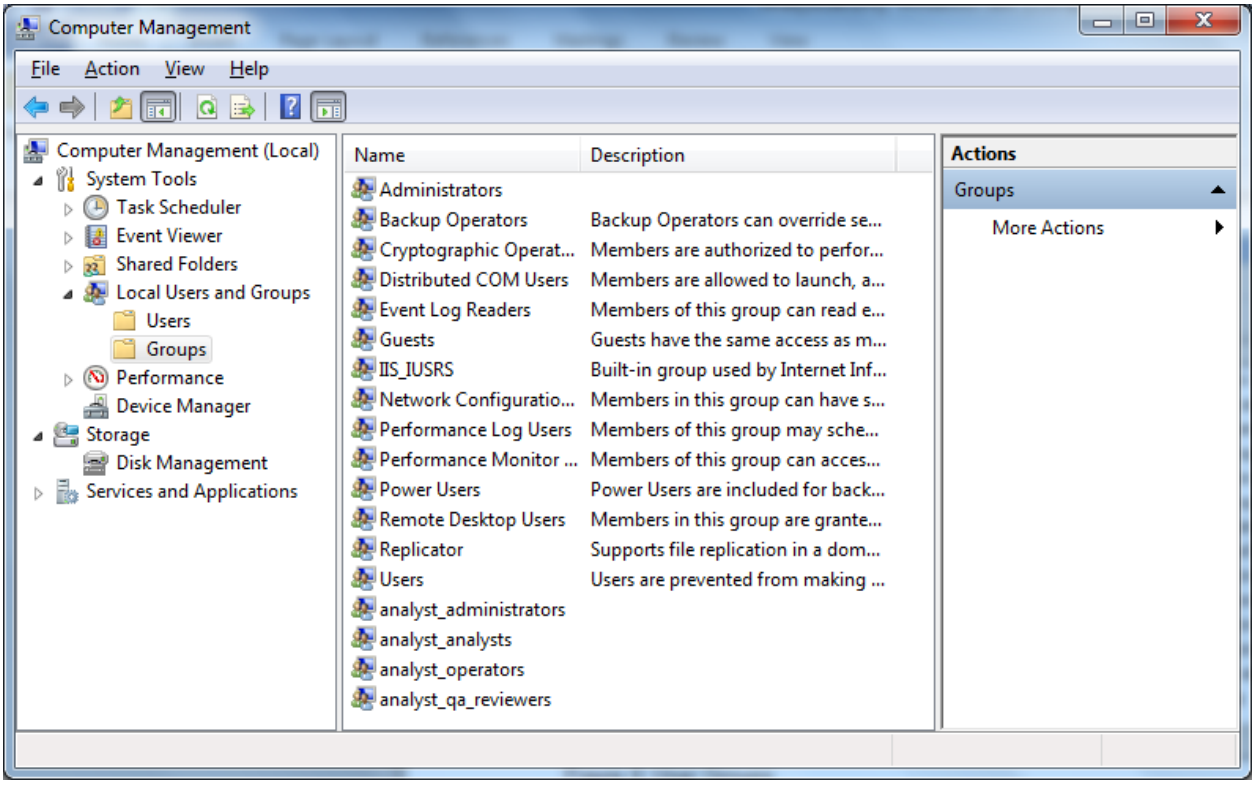



Figure 10: User Groups

Create one group corresponding to each Analyst role, as in table 2. To add a group, Select ***Action->New Group*** from the Main Menu. Enter the group name and a description and click the 'OK' button. Do not add user accounts to the groups at this time.

## Add User Groups to the Analyst® Software Security Configuration

To enable users to launch the Analyst® Software via the Windows User Groups created above, the groups must be added to the Analyst® Software Security Configuration.

In the Analyst® Software, open the Security Configuration dialog box. Ensure that the security mode is set to either Integrated or Mixed-Mode security. Select the 'People' tab. Click the 'New Person…' button. Then associate each Windows User Group with the corresponding Analyst® Software role by selecting the Windows User and clicking the <<Add button to add the appropriate role (shown in Table 2).

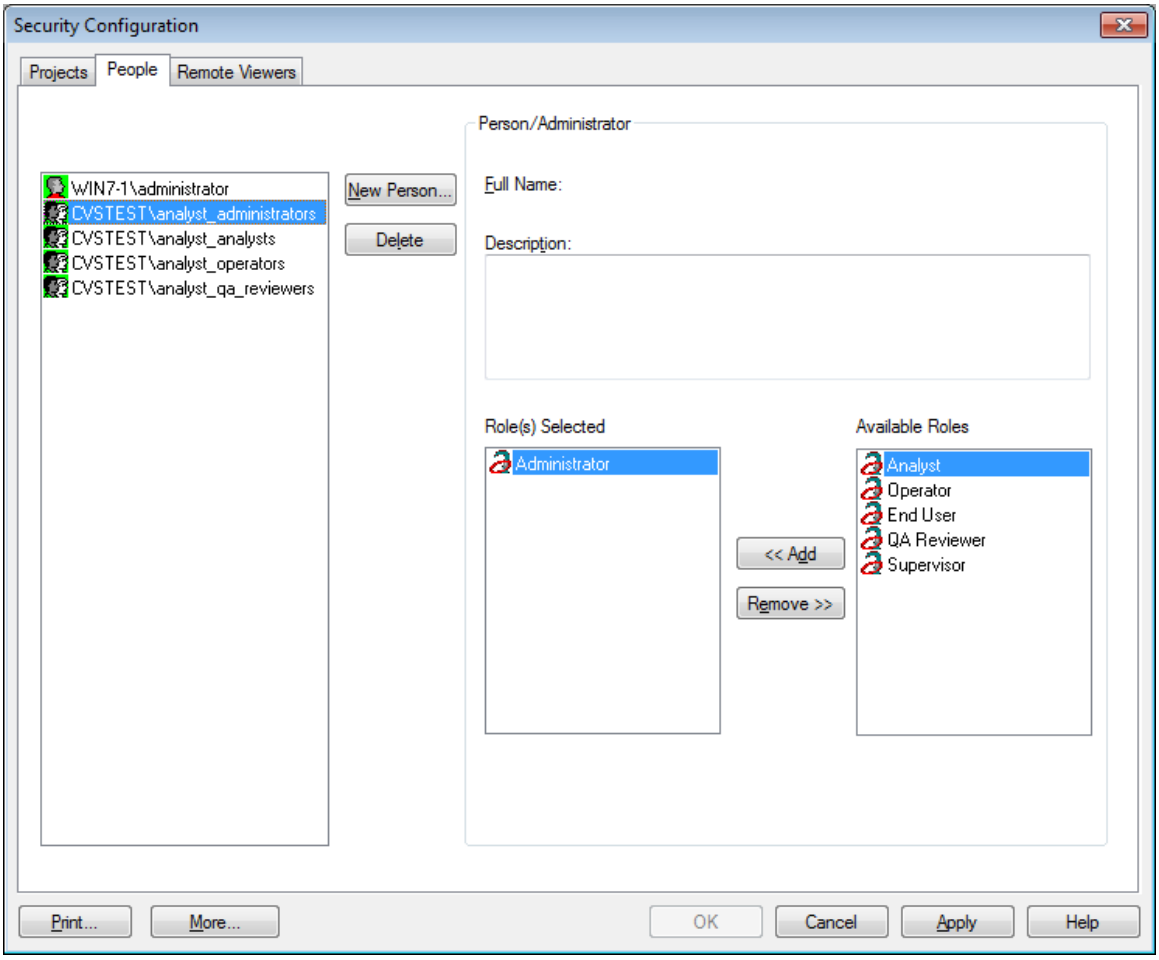



Figure 11: Analyst® Software Security Configuration Dialog

## Set File Privileges

21 CFR Part 11 requires that electronic records be protected from accidental or deliberate deletion. In the Analyst® Software environment, file privileges must be set on the operating system data files used by the Analyst® Software to store data. By default, Analyst® Software stores data in folders under a root directory. This root directory is typically, D:\Analyst Data. But it can be changed depending on the workstation configuration. File privileges should be set on the Analyst® Software root directory so files and folders within the root directory will then inherit the privileges.

### Set File Privileges on the Analyst Root Directory

File privileges are assigned using the Windows User Groups that were created previously: analyst_administrators, analyst_analysts, analyst_operators and analyst_qa_reviewers.

Using Windows Explorer, navigate to the Analyst root directory. Right click to display the properties dialog box, and select the 'Security' tab. First, click the Edit button then add the groups. Next, click the advanced button and set the file privileges, by Windows Group, as follows:

| Permission | Groups | | | | |
|---|---|---|---|---|---|
| | **Analyst_ Administrators** | **Analyst_ Analysts** | **Analyst_ Operators** | **Analyst_ QA_Reviewers** | **Everyone** |
| Full Control | ✓ | (Blank) | (Blank) | (Blank) | (Blank) |
| Traverse Folder / Execute File | ✓ | ✓ | ✓ | ✓ | ✓ |
| List Folder / Read Data | ✓ | ✓ | ✓ | ✓ | ✓ |
| Read Attributes | ✓ | ✓ | ✓ | ✓ | ✓ |
| Read Extended Attributes | ✓ | ✓ | ✓ | ✓ | ✓ |
| Create Files / Write Data | ✓ | ✓ | ✓ | ✓ | ✓ |
| Create Folders / Append Data | ✓ | ✓ | ✓ | ✓ | ✓ |
| Write Attributes | ✓ | ✓ | ✓ | ✓ | ✓ |
| Write Extended Attributes | ✓ | ✓ | ✓ | ✓ | ✓ |
| Delete SubFolder / File | ✓ | Deny | Deny | Deny | (Blank) |
| Delete | ✓ | Deny | Deny | Deny | (Blank) |
| Read Permissions | ✓ | ✓ | ✓ | ✓ | ✓ |
| Change Permissions | ✓ | Deny | Deny | Deny | (Blank) |
| Take Ownership | ✓ | Deny | Deny | Deny | (Blank) |

Table 3: File Privileges by Role

## Manage Users

Maintenance of Analyst® Software user accounts can now be performed solely in Windows 7, without the need to modify the Analyst® Software security configuration.

***Warning:*** *Under no circumstances should an established user account be deleted. Doing so dissociates the user account from entries in the Analyst® Software's audit trail, and makes it possible to inadvertently re-use the account name.*

### Adding Users

For each Analyst® Software user, create a Windows user account. Be sure to enter the user's full name (as this name will be recorded in the Analyst® Software's audit trail). Place a check in the 'User must change password at next login' checkbox. Make sure that the 'Password never expires' checkbox is cleared.

Add the user account to the appropriate Windows group, depending on the user's role. For example, add the administrator for analyst to the analyst_administrators Windows group.

### Disabling User Accounts

To disallow a user all access to the workstation or Analyst® Software and data, edit the user's account and place a check in the 'Account is disabled' checkbox. This prevents the user from logging into the workstation.

### Withdrawing Analyst® Software Access

To prevent a user from accessing the Analyst® Software and data, but to still allow the user to log into the workstation, remove the user's account from all the analyst Windows user groups: analyst_administrators, analyst_analysts, analyst_operators and/or analyst_qa_reviewers.

## Memory Stick Scanning Stations

Even with proper workstation security configuration and industry standard malware precautions (antivirus and firewall software and network security), computer viruses and other destructive software can still infect the workstation when infected memory sticks are used to share data. A simple but important defense is a scanning station. A scanning station is a separate computer with antivirus software installed that is used only for scanning memory sticks. Once the memory stick has been scanned and shown to be malware free then it can be used to share data with the lab workstation. This extra precaution can provide a good way to keep malware from spreading.

## CONCLUSION

The principles and best practices described herein for stand-alone Windows 7 workstations will provide guidance for experienced Windows administrators in identifying items that must be configured along with suggested optimal settings to secure the Analyst® Software.

## CONTACT US

Contact your local AB SCIEX sales representatives or contact AB SCIEX Validation Services at:
**SoftwareValidation@absciex.com**

## REFERENCES

1. Analyst® Software: Laboratory Director's Guide to Security and Regulatory Compliance, Part Number 1014703 B December 2004
2. Good Laboratory Practice Regulations: Ministry of Health and Welfare Ordinance No. 21 (March 26, 1997)
3. The Good Automated Manufacturing Practice (GAMP) Guide for Validation of Automated Systems、 GAMP 4 ISPE/GAMP Forum
4. 21 CFR Part 58, Good Laboratory Practices for non-clinical laboratory studies
5. OECD Principles of Good Laboratory Practice and compliance monitoring, revised in 1997 – Number 1 (ENV/MC/CHEM(98)17)
6. 21 CFR Part 11 – Electronic Records
7. OECD GLP Consesnsus on Computer Systems in the Laboratory
8. GAMP 5
9. Bonnes Pratiques de Laboratoire, Ministere de l'Emploi et de la Sonlidarite Française, N°2000/5 bis, arrêté du 14/03/00 (JO du 23/03/00)
10. Directives Européene 2003/CE de Oct 2003: Annexes 11
11. Strong Passwords. (2005). Retrieved from http://technet.microsoft.com/en-us/library/cc756109(v=ws.10).aspx.

Microsoft and Windows are registered trademarks of Microsoft Corporation.

© 2010 AB SCIEX. The trademarks mentioned herein are the property of AB Sciex Pte. Ltd. or their respective owners. AB SCIEX™ is being used under license.

IN NO EVENT SHALL ABSCIEX BE LIABLE, WHETHER IN CONTRACT, TORT, WARRANTY, OR UNDER ANY STATUTE OR ON ANY OTHER BASIS FOR SPECIAL, INCIDENTAL, INDIRECT, PUNITIVE, MULTIPLE OR CONSEQUENTIAL DAMAGES IN CONNECTION WITH OR ARISING FROM ABSCIEX PRODUCTS AND SERVICES OR THE USE OF THIS DOCUMENT.

Publication number 0490110-01

**Headquarters**
353 Hatch Drive | Foster City CA 94404 USA
Phone 650-638-5800

www.absciex.com

**International Sales**
For our office locations please call the division headquarters or refer to our website at

www.absciex.com/offices